

Categorias de controle

Categorias de controle

Os controles de segurança cibernética são agrupados em três categorias principais:

- Controles administrativos/gerenciais
- Controles técnicos
- Controles físicos/operacionais

Os controles administrativos/gerenciais abordam o componente humano da segurança cibernética. Esses controles incluem políticas e procedimentos que definem como uma organização gerencia dados e define claramente as responsabilidades dos funcionários, incluindo seu papel na proteção da organização. Embora os controles administrativos sejam normalmente baseados em políticas, a aplicação dessas políticas pode exigir o uso de controles técnicos ou físicos.

Os controles técnicos consistem em soluções como firewalls, sistemas de detecção de intrusão (IDS), sistemas de prevenção de intrusão (IPS), produtos antivírus (AV), criptografia, etc. Os controles técnicos podem ser usados de diversas maneiras para atingir as metas e os objetivos organizacionais.

Os controles físicos/operacionais incluem fechaduras de portas, fechaduras de armários, câmeras de vigilância, leitores de crachás, etc. Eles são usados para limitar o acesso físico a bens físicos por pessoal não autorizado.

Tipos de controle

Os tipos de controle incluem, mas não se limitam a:

1. Preventivo
2. Corretivo
3. Detetive
4. Dissuasor

Esses controles atuam em conjunto para fornecer defesa em profundidade e proteger ativos. **Os controles preventivos** são projetados para evitar que um incidente ocorra. **Os controles corretivos** são usados para restaurar um ativo após um incidente. **Os controles de detecção** são implementados para determinar se um incidente ocorreu ou está em andamento. **Os controles de dissuasão** são projetados para desencorajar ataques.

Consulte os gráficos a seguir para obter detalhes específicos sobre cada tipo de controle e sua finalidade.

Controles administrativos/gerenciais		
Nome do controle	Tipo de controle	Objetivo do controle
Privilégio Mínimo	Preventivo	Reduzir o risco e o impacto geral de funcionários mal-intencionados ou contas comprometidas
planos de recuperação de desastres	Corretivo	Garantir a continuidade dos negócios
Políticas de senha	Preventivo	Reduzir a probabilidade de comprometimento da conta por meio de técnicas de ataque de força bruta ou de dicionário.
Políticas de controle de acesso	Preventivo	Reforce a confidencialidade e a integridade definindo quais grupos podem acessar ou modificar os dados.
Políticas de gestão de contas	Preventivo	Gerenciar o ciclo de vida da conta, reduzir a superfície de ataque e limitar o impacto geral causado por

Controles administrativos/gerenciais		
		ex-funcionários insatisfeitos e pelo uso de contas padrão.
Separação de funções	Preventivo	Reduzir o risco e o impacto geral de funcionários mal-intencionados ou contas comprometidas

Controles técnicos		
Nome do controle	Tipo de controle	Objetivo do controle
Firewall	Preventivo	Para filtrar tráfego indesejado ou malicioso e impedir que entre na rede.
IDS/IPS	Detetive	Para detectar e prevenir tráfego anômalo que corresponda a uma assinatura ou regra.
Criptografia	Dissuasor	Garantir a confidencialidade de informações sensíveis.
Cópias de segurança	Corretivo	Restaurar/recuperar de um evento
Gerenciamento de senhas	Preventivo	Reduza a fadiga das senhas
Software antivírus (AV)	Corretivo	Detectar e isolar ameaças conhecidas
Monitoramento, manutenção e intervenção manuais	Preventivo	Necessário para identificar e gerenciar ameaças, riscos ou vulnerabilidades

		em sistemas desatualizados.
--	--	-----------------------------

Controles físicos/operacionais		
Nome do controle	Tipo de controle	Objetivo do controle
Cofre com controle de tempo	Dissuasor	Reduzir a superfície de ataque e o impacto geral das ameaças físicas.
Iluminação adequada	Dissuasor	Atenue as ameaças limitando os esconderijos.
Circuito fechado de televisão (CFTV)	Preventivo/Detetive	O circuito fechado de televisão (CFTV) é uma ferramenta de controle tanto preventiva quanto investigativa, pois sua presença pode reduzir o risco de ocorrência de certos tipos de eventos e pode ser usada após um evento para fornecer informações sobre as condições do ocorrido.
Armários com fechadura (para equipamentos de rede)	Preventivo	Reforce a integridade impedindo que pessoal não autorizado e outros indivíduos acessem ou modifiquem fisicamente os equipamentos da infraestrutura de rede.
Sinalização indicando o fornecedor do serviço de alarme	Dissuasor	Afastar certos tipos de ameaças, fazendo com que a probabilidade de um ataque bem-sucedido

		pareça baixa, pode ser evitada.
Fechaduras	Dissuasor/Preventivo	Reforce a integridade, impedindo e prevenindo o acesso físico de pessoal não autorizado aos ativos.
Detecção e prevenção de incêndios (alarme de incêndio, sistema de sprinklers, etc.)	Detetive/Preventivo	Detectar incêndios em locais físicos e prevenir danos a ativos físicos, como estoque, servidores, etc.